STORY-016 API Access Policies with Open Policy Agent: evidence

STORY-016 works on the demo deployment, with synthetic data; it is not operating in production. Every API request is decided by Open Policy Agent (OPA) before any route sees it. The policy is written in Rego, tested with OPA's own test runner, compiled by OPA 1.21.0 to WebAssembly and evaluated inside the API. It checks the user's role, the resource type, the action and the record's owner or assignee; among its rules is the story's example, 'Case managers can view and work cases assigned to them'. A refusal is recorded in the Security Audit Log with the rule and the policy version.

Rules change without a deployment. On the Access Policies page an administrator switches rules on or off and narrows the roles allowed on any route, with a required reason. Each change is a new write-once version, recorded in the audit log, and applies at once. The policy is a first layer: the route guards stay, so it can refuse what the code would allow, but never allow what the code refuses. Sign-in, the health check and the policy pages themselves are locked, so an administrator cannot be locked out.

Found in our own archive: the earlier 'API governance' service said it enforced OPA policies, but it never called OPA and was never wired into the app. It has been removed and replaced by the real thing.

Checks

- Evidence run, local (scripts/evidence/story-016.mjs, 5 checks passed): by default Sam opens a case assigned to Dana; Morgan switches team visibility off with a reason; at once Sam is refused that case, and the page says why; the refusal is in the audit log with its rule; the defaults are restored.
- API end to end, local (scripts/e2e/policy.mjs, 23 checks): only an administrator reads or changes the policy; refused changes (no reason, unknown rule or route, a role the code does not allow, a locked route, locking the administrator out, no change); a rule switched off applies with no restart; refusals and changes audited; a route narrowed to administrators; history; the stored versions cannot be edited or deleted. It passes twice in a row, restoring the defaults each time.
- OPA's own tests (opa test) on the Rego policy, and unit tests that load the committed WebAssembly policy and check its decisions; a test fails if the Rego and the compiled policy drift apart (manifest hashes).
- Every other suite still passes with the policy in front of every request: 351 end-to-end checks in 9 suites and 719 unit tests.
- Accessibility: /admin/policies passes the WCAG 2.1 AA checks (153 Tab stops, all reached).

Screens

1. An administrator changes a rule
2. Applied at once, no deployment
3. The refusal in the audit log
4. Every version kept

Notes

- The compiled policy is committed with a manifest of hashes, because the demo host cannot run the OPA tool; scripts/opa/build.mjs downloads OPA 1.21.0 (checksum verified), runs its tests and rebuilds it.
- A second API process picks up a change within 5 seconds; the demo runs one.
- All data shown is synthetic.

1. An administrator changes a rule

Morgan switches off team visibility (case managers then work only their own cases, the queue and second-manager reviews) and gives the reason. The page names the engine and the version in force.

Access Policies

Who can reach what in the API, decided by Open Policy Agent and changed without a deploy

Dashboard | Profile & Exemptions | Sign-in security | My Work | Case Management | Compliance | Data Freshness | Audit Log | Staff Access | Leadership | Admin | Access Policies | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Policy in force

Open Policy Agent 1.21.0, compiled to WebAssembly, evaluated inside the API on every request. Policy hash `3ad8ff8be843`.

Version 0: the defaults that come with the code. No one has changed the policy yet.

Every change is recorded in the Security Audit Log, and so is every request the policy refuses. The checks on each route stay in place behind the policy.

Case and account rules

A request is allowed when the route accepts the person's role and at least one of these rules that is on applies. All are on by default, which is how the API has always behaved. Turn one off to take that access away.

Rule	What it allows	Roles	Actions	Applies to	On or off
`case-applicant`	People can view and act on their own applications	Citizen, Case manager, Leadership, Administrator	View and change	Their own case	☑ On
`case-manager-assigned`	Case managers can view and work cases assigned to them	Case manager	View and change	A case assigned to them	☑ On
`case-manager-queue`	Case managers can view and pick up unassigned cases	Case manager	View and change	A case assigned to no one	☑ On
`case-manager-review`	Case managers can view cases waiting for a second-person compliance review	Case manager	View	A case waiting for a compliance review	☑ On
`case-manager-team`	Case managers can view and work every case (team visibility)	Case manager	View and change	Every case	☐ Off Changed, not saved yet
`case-admin`	Administrators can view and work every case	Administrator	View and change	Every case	☑ On
`account-self`	People can view and change their own account	Citizen, Case manager, Leadership, Administrator	View and change	Their own account	☑ On
`audit-trail-self`	People can view their own audit trail	Citizen, Case manager, Leadership, Administrator	View	Their own audit trail	☑ On
`audit-trail-staff`	Case managers and administrators can view anyone's audit trail	Case manager, Administrator	View	Every audit trail	☑ On

Route restrictions

Each route is shown with the roles its code allows. Clear a role to stop it using that route. A role the code does not allow cannot be added here. Sign-in, the health check and these policy pages are locked, so an administrator can never be locked out.

Route	Roles allowed
`GET /health`	Locked
`POST /api/auth/register`	Locked
`POST /api/auth/login`	Locked
`POST /api/auth/mfa/verify`	Locked
`POST /api/auth/logout`	Locked
`POST /api/auth/refresh`	Locked
`GET /api/users/:id`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`PUT /api/users/:id`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/mfa/setup`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/mfa/verify`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/mfa/disable`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/mfa/status`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/exemptions`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/exemptions/check`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/exemptions/stats`	☑ Case manager ☑ Administrator
`POST /api/cases`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/cases`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/cases/managers`	☑ Case manager ☑ Administrator
`GET /api/cases/export`	☑ Case manager ☑ Administrator
`GET /api/cases/stats`	☑ Case manager ☑ Administrator
`GET /api/cases/:id`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/cases/:id/status`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`PUT /api/cases/:id/assignment`	☑ Case manager ☑ Administrator
`POST /api/cases/:id/notes`	☑ Case manager ☑ Administrator
`GET /api/cases/:id/notes`	☑ Case manager ☑ Administrator
`POST /api/cases/:id/documents`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/cases/:id/documents`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`PUT /api/cases/:id`	☑ Case manager ☑ Administrator
`GET /api/compliance/matrix`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/compliance/dashboard`	☑ Case manager ☑ Administrator
`GET /api/compliance/decisions`	☑ Case manager ☑ Administrator
`GET /api/compliance/cases/:caseId`	☑ Case manager ☑ Administrator
`GET /api/compliance/reviews`	☑ Case manager ☑ Administrator
`POST /api/compliance/reviews/:id/resolve`	☑ Case manager ☑ Administrator
`GET /api/freshness/dashboard`	☑ Case manager ☑ Administrator
`POST /api/freshness/probe`	☑ Case manager ☑ Administrator
`GET /api/audit`	☑ Case manager ☑ Administrator
`GET /api/audit/user/:userId`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/audit/resource/:resource/:resourceId`	☑ Case manager ☑ Administrator
`GET /api/audit/stats`	☑ Case manager ☑ Administrator
`GET /api/staff`	☑ Case manager ☑ Administrator
`POST /api/staff/grant`	☑ Case manager ☑ Administrator
`POST /api/staff/:id/revoke`	☑ Case manager ☑ Administrator
`GET /api/notifications`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/notifications/read-all`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/notifications/:id/read`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/dashboards/citizen`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/dashboards/case-manager`	☑ Case manager ☑ Administrator
`GET /api/dashboards/admin`	☑ Administrator
`GET /api/dashboards/leadership`	☑ Leadership ☑ Administrator
`GET /api/policies`	Locked
`PUT /api/policies`	Locked

Save the changes

1 rule and 0 routes changed.

Reason for this change

Pilot: case managers work only their own cases, the queue and reviews.

Required, up to 500 characters. Kept in the Security Audit Log with your name.

Save policy

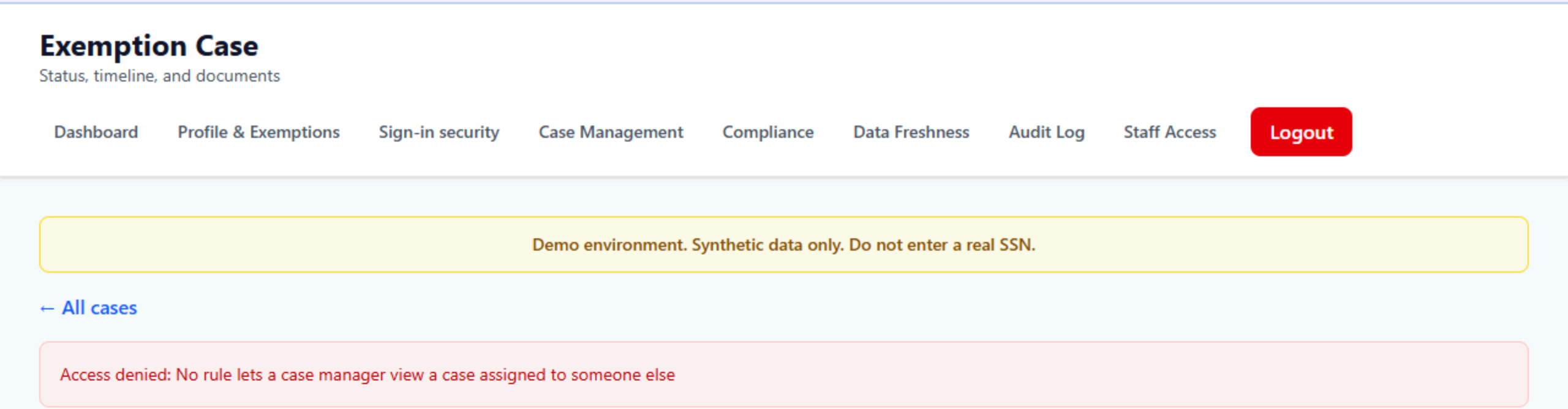
History

The last 0 versions, newest first. A version is never edited or deleted.

No changes yet. The rules and routes above are the defaults that come with the code.

2. Applied at once, no deployment

Seconds later Sam opens a case assigned to Dana and is refused by the policy, with the reason: no rule lets a case manager view a case assigned to someone else.



3. The refusal in the audit log

The Security Audit Log entry for Sam's refused request names the policy rule and version that refused it.

Security Audit Log

Every sign-in, refusal, data access, change and alert

Dashboard | Profile & Exemptions | Sign-in security | Case Management | Compliance | Data Freshness | Audit Log | Staff Access | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Write-once
The database refuses any edit or deletion of an entry.

Kept for 7 years
213 entries, 24 of them refusals or failures.

No personal data
SSNs, passwords, codes and tokens are removed before an entry is written.

From: mm/dd/yyyy | To: mm/dd/yyyy | User: .ortiz@example.com | Event: Access denied | Area: All | Result: All | Search | Reset

When	User	Event	Area	Result	Details	From
10/14/2026, 8:07:12 AM	sam.ortiz@example.com	Access denied ACCESS_DENIED	cases	Refused or failed	GET /api/cases/5aebe2e5-9c72-4f0d-9d50-ea4a339be53e → 403 · rule: no-matching-rule · No rule lets a case manager view a case assigned to someone else (policy...	::1
10/14/2026, 8:07:12 AM	sam.ortiz@example.com	Access denied ACCESS_DENIED	dashboards	Refused or failed	GET /api/dashboards/admin → 403 · rule: route-roles · Only administrators can use this route (policy version 1)	::1

2 entries

Previous | Page 1 of 1 | Next

4. Every version kept

The policy history after the defaults were restored: each version with who changed it, when, what changed and why.

Access Policies

Who can reach what in the API, decided by Open Policy Agent and changed without a deploy

Dashboard | Profile & Exemptions | Sign-in security | My Work | Case Management | Compliance | Data Freshness | Audit Log | Staff Access | Leadership | Admin | Access Policies | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Policy in force

Open Policy Agent 1.21.0, compiled to WebAssembly, evaluated inside the API on every request. Policy hash `3ad8ff8be843`.

Version 2, saved 10/14/2026, 8:07:15 AM by morgan.lee@example.com. Reason: Pilot over: team visibility back on.

Every change is recorded in the Security Audit Log, and so is every request the policy refuses. The checks on each route stay in place behind the policy.

Case and account rules

A request is allowed when the route accepts the person's role and at least one of these rules that is on applies. All are on by default, which is how the API has always behaved. Turn one off to take that access away.

Rule	What it allows	Roles	Actions	Applies to	On or off
`case-applicant`	People can view and act on their own applications	Citizen, Case manager, Leadership, Administrator	View and change	Their own case	☑ On
`case-manager-assigned`	Case managers can view and work cases assigned to them	Case manager	View and change	A case assigned to them	☑ On
`case-manager-queue`	Case managers can view and pick up unassigned cases	Case manager	View and change	A case assigned to no one	☑ On
`case-manager-review`	Case managers can view cases waiting for a second-person compliance review	Case manager	View	A case waiting for a compliance review	☑ On
`case-manager-team`	Case managers can view and work every case (team visibility)	Case manager	View and change	Every case	☑ On
`case-admin`	Administrators can view and work every case	Administrator	View and change	Every case	☑ On
`account-self`	People can view and change their own account	Citizen, Case manager, Leadership, Administrator	View and change	Their own account	☑ On
`audit-trail-self`	People can view their own audit trail	Citizen, Case manager, Leadership, Administrator	View	Their own audit trail	☑ On
`audit-trail-staff`	Case managers and administrators can view anyone's audit trail	Case manager, Administrator	View	Every audit trail	☑ On

Route restrictions

Each route is shown with the roles its code allows. Clear a role to stop it using that route. A role the code does not allow cannot be added here. Sign-in, the health check and these policy pages are locked, so an administrator can never be locked out.

Route	Roles allowed
`GET /health`	Locked
`POST /api/auth/register`	Locked
`POST /api/auth/login`	Locked
`POST /api/auth/mfa/verify`	Locked
`POST /api/auth/logout`	Locked
`POST /api/auth/refresh`	Locked
`GET /api/users/:id`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`PUT /api/users/:id`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/mfa/setup`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/mfa/verify`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/mfa/disable`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/mfa/status`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/exemptions`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/exemptions/check`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/exemptions/stats`	☑ Case manager ☑ Administrator
`POST /api/cases`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/cases`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/cases/managers`	☑ Case manager ☑ Administrator
`GET /api/cases/export`	☑ Case manager ☑ Administrator
`GET /api/cases/stats`	☑ Case manager ☑ Administrator
`GET /api/cases/:id`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/cases/:id/status`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`PUT /api/cases/:id/assignment`	☑ Case manager ☑ Administrator
`POST /api/cases/:id/notes`	☑ Case manager ☑ Administrator
`GET /api/cases/:id/notes`	☑ Case manager ☑ Administrator
`POST /api/cases/:id/documents`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/cases/:id/documents`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`PUT /api/cases/:id`	☑ Case manager ☑ Administrator
`GET /api/compliance/matrix`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/compliance/dashboard`	☑ Case manager ☑ Administrator
`GET /api/compliance/decisions`	☑ Case manager ☑ Administrator
`GET /api/compliance/cases/:caseId`	☑ Case manager ☑ Administrator
`GET /api/compliance/reviews`	☑ Case manager ☑ Administrator
`POST /api/compliance/reviews/:id/resolve`	☑ Case manager ☑ Administrator
`GET /api/freshness/dashboard`	☑ Case manager ☑ Administrator
`POST /api/freshness/probe`	☑ Case manager ☑ Administrator
`GET /api/audit`	☑ Case manager ☑ Administrator
`GET /api/audit/user/:userId`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/audit/resource/:resource/:resourceId`	☑ Case manager ☑ Administrator
`GET /api/audit/stats`	☑ Case manager ☑ Administrator
`GET /api/staff`	☑ Case manager ☑ Administrator
`POST /api/staff/grant`	☑ Case manager ☑ Administrator
`POST /api/staff/:id/revoke`	☑ Case manager ☑ Administrator
`GET /api/notifications`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/notifications/read-all`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`POST /api/notifications/:id/read`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/dashboards/citizen`	☑ Citizen ☑ Case manager ☑ Leadership ☑ Administrator
`GET /api/dashboards/case-manager`	☑ Case manager ☑ Administrator
`GET /api/dashboards/admin`	☑ Administrator
`GET /api/dashboards/leadership`	☑ Leadership ☑ Administrator
`GET /api/policies`	Locked
`PUT /api/policies`	Locked

Save the changes

Nothing has changed yet.

Reason for this change

Required, up to 500 characters. Kept in the Security Audit Log with your name.

Save policy

History

The last 2 versions, newest first. A version is never edited or deleted.

Version	When	Who	What changed	Reason
2	10/14/2026, 8:07:15 AM	morgan.lee@example.com	case-manager-team turned on	Pilot over: team visibility back on.
1	10/14/2026, 8:07:11 AM	morgan.lee@example.com	case-manager-team turned off	Pilot: case managers work only their own cases, the queue and reviews.